

- Filename: comptia-pentest-plus-pt0-002-1-3-1-legal-concepts-and-documents.md
- Show Name: Pentest+ (PT0-002)
- Topic Name: Planning and Scoping
- Episode Name: Legal Concepts and Documents

Legal Concepts and Documents

Objectives:

- List and define commonly used legal terms and documents associated with Pentesting
-
- SLA
 - Defines what services can be expected by the customer
 - Services will be defined
 - Measurable expectations will be set
 - Both Service Provider and Customer will have responsibilities defined
 - Sanctions and reparations will be set
 - Mitigations for possible violations
 - Protocol or process for adding/removing metrics
 - Remote Automated Scan
 - <https://www.pronetcorp.com/pronet-penetration-testing-service-agreement/>
 - Confidentiality Agreement
 - aka NDA
 - Pentesters have access to client's sensitive info
 - Client's have access to pentester's proprietary process, tools, etc
 - NDA legally binds parties from disclosing or disseminating
 - SOW
 - Highly detailed document that explains...
 - The specific work to be performed
 - Vulnerability scan/assessment
 - Remediation
 - Billing
 - Timeframe
 - Caveats
 - Disclaimers
 - Accidental downtime due to scans/activity
 - Deliverables
 - All parties must sign off on the SOW
 - <http://www.projectmanagementdocs.com/project-documents/statement-of-work.html>
 - Master Service Agreement(MSA)
 - Lays out a general set of terms and definitions that are agreed upon by both signatories

- This saves time for future work
 - Terms used in the MSA can be referenced by subsequent docs
 - Only new work items will need to be negotiated
- Common MSA Terms
 - Payment Terms
 - Delivery Requirements
 - Intellectual Property Rights
 - Warranties
 - Limitations
 - Dispute Resolution
 - Confidentiality
 - Work Standards
- http://www.cengage.com/resource_uploads/downloads/143548360X_429597.pdf
- <https://brandcdn.exacttarget.com/sites/exacttarget/files/master-services-agreement.pdf>
- Permission to Attack
 - Get-out-of-jail-free card
 - Obtain signature from proper signing authority
 - Third-party provider authorization when necessary
 - Common elements of authorization forms
 - Proper authority defined
 - Authorized testers defined
 - Systems for testing defined
 - Authorized time period for test defined
 - <https://darknetdiaries.com/episode/59/>
 - Computer Network Systems
 - Physical Infrastructure
 - Cloud